APPLICATION SECURITY OFFLINE AUDIT

Strapi source review & hardening overlay

STRAPI 5.57.0 MONOREPO / 10 OCTOBER 2026

Outcome: material source-level risks remain.
Targeted fixes are provided for 39 files. This is an offline assessment, not a completed live penetration test or production approval.

Executive summary

The uploaded archive contains the Strapi framework, example applications and generators. It does not uniquely identify the deployed application, its role permissions or its infrastructure. The review found risky development exposure and credential defaults, permissive credentialed CORS, URL-fetch validation gaps, reset-token weaknesses, legacy export encryption and token-handling risks.

All 104 checklist items receive a disposition. Source fixes and isolated tests must not be mistaken for deployment verification. Unknown items use Not verified, deliberately extending the requested status set so missing evidence is not mislabeled Pass or Not applicable.

104 checklist entries
Baseline dispositions; see section 6

12 finding groups
Conditional severity; see section 3

39 fixed files
Overlay, not a complete application

Baseline status: Pass: 4, Not verified: 83, Fail: 17

Validation: 19 focused mocked/source-level test groups and 3 static Compose policy checks passed; git apply --check passed.

Not performed: Full build/typecheck, Docker/database integration, deployed endpoint testing, remote scans, brute force, load/DoS tests or secret-history scanning.

Missing input: The referenced port-security document was not supplied or identifiable in the archive. Loopback/environment changes are a provisional baseline.

CONFIDENTIAL - PROJECT OWNER REVIEW
Evidence references use original uploaded files, not patched line offsets.

1. Scope, stack & trust boundaries

Source authorization was asserted in prompt.txt, line 3. Testing was limited to uploaded files, isolated sandbox checks, and public dependency-advisory lookups. No production or third-party system was contacted for attack testing.

Inputs: Source RAR, expanded AppSec PDF, prompt.txt and pdf design.txt. The policy referenced as a port-security document is absent.

Stack: Strapi 5.57.0; Node.js and TypeScript/JavaScript; React admin; Koa middleware; Knex SQL layer; optional GraphQL/Apollo; Yarn 4 workspaces; PostgreSQL/MySQL/MariaDB development containers and SQLite examples.

Inventory: 6,303 source/config files pattern-scanned; 65 package manifests inventoried; 268 literal route candidates. Dynamic CRUD/plugin routes and effective permission grants require runtime enumeration.

Exclusions: Vendored node_modules, .git history and build/dist/cache trees were excluded. Pattern matches are candidates, not vulnerabilities. Root yarn.lock only was checked against OSV.

2. Provisional threat model

Rank	Threat	Checklist mapping
01	Exposed databases / default credentials	C040, C050, C077
02	Forged or stolen long-lived sessions	C027, C030, C087
03	Cross-user or tenant data access	C020, C021, C066
04	Privileged routes / request binding	C022, C023, C025
05	Internal-network URL fetches	C011, C071
06	Reset-link theft and parallel use	C028, C034
07	Dependency exploitation	C052, C054
08	Script/content and browser trust risks	C010, C055, C085
09	GraphQL / upload resource exhaustion	C079, C080, C096
10	Archive disclosure or tampering	C042, C091

Assets: database contents, administrator access, secrets, uploads, archives and availability. Boundaries: browser/API; admin/content API; app/database; app/outbound network; host/container; build/dependencies. STRIDE and attacker models are expanded in evidence/threat-model.md.

3. Findings register

Severity is qualitative and conditional on deployment, sensitive data and reachable features. No Critical exploit was established. High/Medium labels prioritize remediation; they do not attest production exploitability. Final CVSS scores and named owners require application context.

ID / severity	Finding	Remediation state
F01 / High	Broad service bindings and host-port defaults	Source-remediated; deployment unverified
F02 / High	Known credentials and weak example signing keys	Source-remediated in listed configs; rotation required
F03 / High	Credentialed CORS reflects arbitrary origins	Source-remediated; browser retest required
F04 / High	URL-import SSRF redirect and DNS-validation gaps	Partially mitigated
F05 / High	Reset tokens lack expiry and atomic consumption	Partially mitigated; schema migration required
F06 / High	Export encryption uses unauthenticated legacy modes	Open — compatibility-sensitive
F07 / Medium	GraphQL depth and pagination unbounded by default	Partially mitigated
F08 / Medium	Logout reports success when revocation throws	Source-remediated exception path
F09 / Medium	Long-lived legacy tokens and script-readable storage	Open — client/server migration required
F10 / High	Dependency advisory matches need reachability triage	Open — advisory matches, not confirmed exploits
F11 / Medium	Documentation CSP permits inline/CDN scripts	Open — UI-compatible CSP migration required
F12 / Medium	Local upload provider serves from application public directory	Open — storage/deployment change required

Release blockers: SSRF rebinding/egress; atomic reset-token use; export authenticated-encryption migration; legacy token revocation/storage; dependency reachability/upgrades; production upload origin and CSP; full staging authorization and infrastructure retest.

Sources and original line locations are provided below. S01-S43 aliases resolve to full repository-relative paths in section 7. Detailed machine-readable records are in findings.json.

4. Finding details

F01 Broad service bindings and host-port defaults [High]

Original evidence: S01:13-14,27-28; S03:11-12,25-26,38-39; S34:37; S35:20-23

```
ports: ['5432:5432']
server.listen(port, () => { ... })
```

Impact. All-interface host publication and unspecified helper listen host can expose services on an internet-facing development machine.

Remediation. Bind to loopback by default; environment-control host ports and helper address; validate listener range. Standard container protocol ports are retained.

Remaining risk. Explicit broad bind overrides, container topology, IPv6 and firewall behavior still require operator review.

Source-remediated; deployment unverified | Proposed owner: Platform / DevOps

F02 Known credentials and weak example signing keys [High]

Original evidence: S01:7-10,19-23; S05:3-30; S06:16-43; S04:12-14

```
POSTGRES_PASSWORD: strapi
secret: env('ADMIN_JWT_SECRET', 'example-token')
```

Impact. Known SQL passwords and predictable signing/encryption fallbacks are unsafe if copied into deployment. These are example values, not confirmed live secrets.

Remediation. Remove listed fallbacks; require SQL/Compose secrets, strong example app keys and operator-selected images. Rotate previously used credentials separately.

Remaining risk. Existing database passwords are not rotated by editing Compose. Placeholder fixtures remain non-production inputs; entropy and key invalidation need review.

Source-remediated in listed configs; rotation required | Proposed owner: Application + Platform

F03 Credentialed CORS reflects arbitrary origins [High]

Original evidence: S07:16-22,64-70

```
origin: '*', credentials: true
if (normalizedOrigins.includes('*')) return requestOrigin;
```

Impact. The wildcard origin branch reflects arbitrary origins while credentials are enabled. Exposure depends on cross-site credential availability.

Remediation. Default to no cross-origin permission and no credentials; reject null/absent origins and credentialed wildcard configurations, including dynamic results.

Remaining risk. Trusted cross-origin clients need explicit origins. CORS is not authorization or CSRF protection; optional middleware paths need browser retests.

Source-remediated; browser retest required | Proposed owner: Application security

4. Finding details - continued

F04 URL-import SSRF redirect and DNS-validation gaps [High]

Original evidence: S08:133-149; S28:114-131

```
await dns.lookup(parsedUrl.hostname);
await doFetch(url, { signal: AbortSignal.timeout(FETCH_TIMEOUT_MS) });
```

Impact. A URL is resolved once before fetch; automatic redirects and independent connection-time DNS resolution undermine that check.

Remediation. Reject redirects; check every returned DNS answer and expand blocked address ranges. Mocked checks cover private/mapped addresses and redirect options.

Remaining risk. DNS rebinding and proxy resolution are not fixed. Pin validation at connection time, allowlist destinations and restrict egress, or disable URL import.

Partially mitigated | Proposed owner: Application + Platform

F05 Reset tokens lack expiry and atomic consumption [High]

Original evidence: S09:288-299,503-537; S10:42-53

```
findOne({ where: { resetPasswordToken: code } });
await getService('user').edit(user.id, { resetPasswordToken: null, password });
```

Impact. Reset tokens had no expiry; a separate read then password update permits concurrent token use.

Remediation. Add private expiry field, issue 15-minute links, validate expiry and clear token plus expiry. Legacy links without expiry are rejected.

Remaining risk. Schema migration is required. Atomic consumption, confirmation expiry and legacy JWT invalidation remain open; isolated tests do not prove concurrency safety.

Partially mitigated; schema migration required | Proposed owner: Authentication team

F06 Export encryption uses unauthenticated legacy modes [High]

Original evidence: S11:10-32,47-51; S12:140

```
algorithm: Algorithm = 'aes-128-ecb'
const hashedKey = scryptSync(key, '', 16);
```

Impact. Export encryption defaults to ECB; CBC variants derive IVs from the key. Neither supplies authenticated archive protection.

Remediation. No incompatible crypto change was made. Plan a versioned AEAD archive with random KDF salt/nonce and coordinated importer/exporter migration.

Remaining risk. Existing exports remain unauthenticated. Restrict archive access and migrate only trusted legacy data; do not change one cipher default in isolation.

Open — compatibility-sensitive | Proposed owner: Data-transfer maintainers

4. Finding details - continued

F07 GraphQL depth and pagination unbounded by default [Medium]

Original evidence: S13:5-6; S14:149-158,203-206

```
maxLimit: -1
validationRules: [depthLimit(configuredDepthLimit as number)]
```

Impact. GraphQL pagination defaults to unlimited and depth is unset; bootstrap warns instead of enforcing safe finite defaults.

Remediation. Set default page 25, maximum 100 and depth 10; disable production introspection/HTTP batching and explicitly enable Apollo CSRF prevention.

Remaining risk. Depth is not cost. Alias/fragment amplification, per-operation throttling, timeouts, suggestions and explicit app overrides remain to test.

Partially mitigated | Proposed owner: GraphQL maintainers

F08 Logout reports success when revocation throws [Medium]

Original evidence: S09:372-390

```
catch (err) { strapi.log.error('UP logout failed', err); }
return ctx.send({ ok: true });
```

Impact. Refresh-mode logout swallowed backend revocation exceptions and returned success, potentially leaving sessions usable.

Remediation. Throw a generic application error when revocation raises an exception, rather than reporting success. Mocked failure and success checks pass.

Remaining risk. Non-throwing unsuccessful revocation and real old-token replay are not verified. Legacy stateless mode still needs a revocation-aware migration.

Source-remediated exception path | Proposed owner: Authentication team

F09 Long-lived legacy tokens and script-readable storage [Medium]

Original evidence: S23:14-29; S22:87-99; S15:131-156

```
jwt: { expiresIn: '30d' }
localStorage.setItem(STORAGE_KEYS.TOKEN, JSON.stringify(token));
```

Impact. Legacy JWTs default to 30 days; verification lacks issuer/audience checks. Remember-me admin access tokens are written to localStorage.

Remediation. No disruptive auth-mode/client change was made. Migrate to short access tokens, refresh rotation/reuse detection and protected cookie flows with CSRF controls.

Remaining risk. Script-readable storage magnifies an XSS breach but is not proof of XSS. Client compatibility, environment claims and replay/revocation need staging tests.

Open — client/server migration required | Proposed owner: Authentication + Frontend

4. Finding details - continued

F10 Dependency advisory matches need reachability triage [High]

Original evidence: S33; evidence/osv-results.json; evidence/osv-advisories.json

```
2,838 resolved npm package/version pairs queried
44 matching pairs; 111 unique advisory IDs
```

Impact. OSV returned advisory matches for 44 of 2,838 root-lock package/version pairs, spanning 111 unique IDs. This does not prove reachability.

Remediation. No automatic upgrades were made. Trace dependency chains and affected functions, choose reviewed fixed versions, regenerate locks and run full tests.

Remaining risk. Runtime versus dev dependency reachability, nested lockfiles and advisory-specific severities remain to triage. Aggregate High is remediation priority only.

Open — advisory matches, not confirmed exploits | Proposed owner: Dependency owners

F11 Documentation CSP permits inline/CDN scripts [Medium]

Original evidence: S16:49-75

```
'script-src': ["'self'", "'unsafe-inline'", 'cdn.jsdelivr.net']
```

Impact. Documentation/playground paths permit inline scripts and third-party CDN exceptions, weakening the checklist CSP baseline.

Remediation. No UI-breaking policy change was made. Remove unnecessary production docs/playgrounds or migrate scripts to nonce/hash policy and reviewed origins/SRI.

Remaining risk. No XSS exploit was demonstrated. Render each production surface after policy changes; blindly dropping inline permissions can break required interfaces.

Open — UI-compatible CSP migration required | Proposed owner: Frontend + Platform

F12 Local upload provider serves from application public directory [Medium]

Original evidence: S17:53-54,87-96; S36:280-287

```
path.resolve(strapi.dirs.static.public, 'uploads')
fs.createWriteStream(path.join(uploadPath, `${file.hash}${file.ext}`))
```

Impact. The local provider stores under the app public directory. Allowed active content could share the application origin; this was not payload-tested.

Remediation. No storage migration was made. Use a separate non-executable upload origin; deny/sanitize active SVG/HTML and enforce response/download controls.

Remaining risk. MIME detection is not active-content sanitization. Provider URL migration, authorization, signed URL expiry and real browser behavior need verification.

Open — storage/deployment change required | Proposed owner: Media + Platform

5. Applying changes & verification

The fixed-code folder is a 39-file overlay, not a full application. Originals were preserved. Use the patch or copy the overlay into a same-version staging checkout, never both. The manifest contains before/after SHA-256 hashes.

Safe sequence

01. Back up code, database, uploads and exports. Confirm source hashes and apply the patch in staging.

02. Set independent random secrets and unique SQL passwords. Choose tested pinned images/digests compatible with existing volumes; do not silently upgrade database majors.

03. Review/migrate resetPasswordTokenExpiresAt with custom user-model extensions. Old links intentionally become invalid. Do not permit unreviewed production schema sync.

04. Configure trusted CORS origins. Check loopback defaults versus container networking: explicit 0.0.0.0 may be needed inside an isolated container, not on public host ports.

05. Rebuild with pinned toolchain and reviewed install scripts; run complete repository tests and a full typecheck. Follow README.md for commands and environment variables.

06. Run staging endpoint/role/ownership tests, token replay and concurrent reset tests; verify TLS, headers, cookies, cache policy, uploads, GraphQL cost and network egress.

Verified here

Nineteen isolated source-level regression groups passed: CORS defaults/allowlists, configuration/secret behavior, GraphQL defaults, URL-import blocked addresses/redirect option, logout exception handling, reset expiry/clearing and changed JS/TS syntax. Three Compose YAML/interpolation policy checks passed. Patch applicability passed against uploaded originals.

Not verified here

No full typecheck/build, running Strapi, real SQL migration, Docker Compose launch, browser attack flow, cloud/OOB probe or remote penetration test occurred. Mocked tests establish selected code behavior only. Reset concurrency and SSRF DNS pinning remain unresolved. The missing port-security document prevents policy compliance sign-off.

Artifact index

README.md - application/rollback cautions and test commands.
checklist-coverage.csv/json - all 104 baseline dispositions.
findings.json - full evidence excerpts, impact, fixes, owners and residuals.
evidence/ - source candidates, routes, manifests and OSV responses.
Security-Fixes-Plain-English.md - non-technical handoff.

6. Complete checklist coverage

Entries 001-009 of 104. Status describes the uploaded baseline. 'Not verified' is an evidence gap, not Pass or N/A. For unknown rows, severity is review priority, not a confirmed finding.

C001 / P1 Define scope and rules of engagement

Pass | Low prompt.txt:3; evidence/scope.md:1-12

Ownership/authorization asserted. This assessment is confined to supplied source and sandbox-only checks; no remote systems are tested.

C002 / P1 Inventory entry points

Not verified | High S18:76-95; evidence/route-candidates.csv

Literal routes inventoried, but dynamic CRUD factories, enabled plugins and stored permissions require a runtime route dump.

C003 / P1 Identify roles and trust boundaries

Not verified | High S18:85-92; S40:99-134

Admin/content API strategies exist. Effective roles and object ownership policies require the deployed permission store and test accounts.

C004 / P2 Lightweight threat model

Pass | Low evidence/threat-model.md:1-16

A scoped top-ten threat model is included. Ranking is provisional without deployment and business context.

C005 / P2 Tech stack and dependency fingerprint

Pass | Low S31:1-3; S32:24-29; S33:1-8

Strapi 5.57.0 monorepo; Node.js, TypeScript/JavaScript, React admin, Koa, Knex, optional GraphQL/Apollo, Yarn 4 workspaces and SQL/SQLite providers.

C006 / P1 SQL / NoSQL injection

Not verified | High S20:49-59,115-163; S19:24-30

Query helper validates operators; controllers validate query input. Raw-query candidates are inventoried, not exhaustively taint-traced.

C007 / P1 OS command injection

Not verified | High evidence/source-pattern-inventory.json

Shell/dynamic-code candidates include CLI/build paths. No confirmed HTTP-input-to-command exploit was established; full tracing remains.

C008 / P1 Path traversal & file I/O

Not verified | High S08:62-83,205-235; S17:87-96

URL filenames use basename and upload paths use generated hash/ext. Archive extraction and symlink safety need a complete path review.

C009 / P1 Unsafe deserialization

Not verified | High evidence/source-pattern-inventory.json; S32:24-29

JavaScript source and dependency manifests were inspected. No blanket assurance for all serializers or installed extensions is justified.

6. Complete checklist coverage

Entries 010-018 of 104. Status describes the uploaded baseline. 'Not verified' is an evidence gap, not Pass or N/A. For unknown rows, severity is review priority, not a confirmed finding.

C010 / P1 DOM-based & server-side XSS

Not verified | High S25:12-20; S26:67-74

WYSIWYG preview sanitizes output with DOMPurify. This is a positive control, not proof that every rendering context is safe.

C011 / P1 Server-side request forgery (code level)

Fail | High S08:133-149; S28:114-131

URL import checks DNS once then fetch follows redirects; DNS lookup is not pinned to the connection. F04 partially mitigated; webhook egress also needs review.

C012 / P2 Server-side template injection (SSTI)

Not verified | Medium S09:506-521; evidence/source-pattern-inventory.json

Email templating is used. Administrator-authored template reachability and safe interpolation need a complete review.

C013 / P2 XXE and XML handling

Not verified | Medium S36:280-287

SVG/XML-like uploads are accepted under allowlists. No complete parser configuration inventory or XXE execution test was performed.

C014 / P2 LDAP / XPath / header / log injection

Not verified | Medium S28:124-129; S27:31-59

Webhook headers and public errors carry configured values. LDAP/XPath applicability and CRLF/log encoding paths are not fully established.

C015 / P2 Open redirects and unvalidated forwards

Not verified | Medium S23:44-69; S09:452-462

OAuth callback validation compares exact origin and pathname. Other redirect paths and query-parameter abuse require review.

C016 / P2 Prototype pollution & unsafe object merging (JS)

Not verified | Medium S14:222-232; S16:31-34; evidence/osv-results.json

Object merging is present; OSV flags a GraphQL utility dependency. Untrusted-data reachability is not confirmed.

C017 / P2 Regular-expression DoS (ReDoS)

Not verified | Medium S08:66-68; evidence/source-pattern-inventory.json

Regular expressions were inventoried selectively. No recheck/RE2 or adversarial timing analysis across all regexes was completed.

C018 / P2 File upload handling (code)

Fail | Medium S17:53-54,87-96; S36:280-287

Default local upload storage is under the public directory, not a separate origin. SVG allowance depends on config. F12 remains; no XSS exploit is asserted.

6. Complete checklist coverage

Entries 019-027 of 104. Status describes the uploaded baseline. 'Not verified' is an evidence gap, not Pass or N/A. For unknown rows, severity is review priority, not a confirmed finding.

C019 / P3 Insecure use of reflection, dynamic code, and eval

Not verified | Medium evidence/source-pattern-inventory.json

Dynamic-code candidates are locations for follow-up, not demonstrated input-to-eval paths.

C020 / P1 BOLA / IDOR

Not verified | High S19:36-44; S39:97-110

ID-based lookups are present. Router authorization does not prove object ownership; intended access policy and cross-user tests are missing.

C021 / P1 Multi-tenant isolation

Not verified | High S19:24-44; evidence/route-candidates.csv

No target tenant model or tenant contract was supplied. Do not assume generic framework queries implement application tenant isolation.

C022 / P1 Mass assignment / request binding

Not verified | High S19:60-66,89-95; S39:137-141

Core CRUD sanitizes input, but user update spreads request body. Role and sensitive-field restrictions require route/permission validation before declaring an exploit.

C023 / P1 Function-level access control (BFLA)

Not verified | High S18:85-92; S40:123-134

Central authenticate/verify middleware exists, with explicit auth:false support. Every route and granted permission must be checked.

C024 / P2 Property-level authorization (excessive data exposure)

Not verified | Medium S19:29-30,42-44; S10:35-52

Output sanitization and private password/token fields are observed. Per-role serializer coverage is not complete.

C025 / P2 Privilege escalation paths

Not verified | High S39:49-81,137-141

User creation/update supports roles. Effective route permissions and elevated-actor checks must be tested; no privilege escalation is asserted.

C026 / P2 Authorization tests exist

Not verified | Medium evidence/packages.json; evidence/route-candidates.csv

Repository tests exist, but no proof of an exhaustive role-by-endpoint and cross-tenant test matrix was obtained.

C027 / P1 Password and credential handling

Fail | High S01:7-10; S05:3-30; S06:16-20

Known example SQL passwords and signing/encryption fallback values exist. F02 is source-remediated in listed configs; rotation and TLS remain operator tasks.

6. Complete checklist coverage

Entries 028-036 of 104. Status describes the uploaded baseline. 'Not verified' is an evidence gap, not Pass or N/A. For unknown rows, severity is review priority, not a confirmed finding.

C028 / P1 Account recovery and verification flows

Fail | High S09:288-299,503-537; S10:42-53

Reset tokens had no stored expiry. F05 adds expiry and rejects legacy links, but atomic one-time consumption and confirmation expiry remain unresolved.

C029 / P1 Session management

Fail | Medium S23:14-29; S09:356-375

Legacy mode uses long-lived stateless JWTs and has no logout endpoint. Refresh mode also swallowed revocation errors. F08/F09 need session migration and runtime replay tests.

C030 / P2 JWT implementation

Fail | Medium S22:87-99; S23:14-22

Algorithm is pinned, but legacy verification supplies no issuer/audience constraints and defaults to 30-day tokens. F09 remains; application claim policy is needed.

C031 / P2 MFA implementation

Not verified | High S09:136-200; evidence/route-candidates.csv

No deployed MFA policy, enrollment or recovery configuration was supplied. Absence of a demonstrated MFA bypass is not a pass.

C032 / P2 OAuth / OIDC / SSO

Not verified | Medium S23:44-69; S09:434-470

Callback URL checks exist. Provider state, nonce, PKCE and verified-email linking require provider-specific configuration and tests.

C033 / P2 CSRF defenses

Not verified | Medium S29:43-69; S23:23-29

Refresh cookies use SameSite defaults; the patch enables Apollo CSRF prevention. Cookie-based write and refresh endpoints still need cross-site testing.

C034 / P1 Race conditions (TOCTOU)

Fail | High S09:288-299

Reset-token read and password update remain separate operations. Two parallel requests may consume the same link. F05 remains partially fixed pending atomic consumption.

C035 / P1 Workflow step bypasses

Not verified | High S09:181-195,665-701

Confirmation/block state is checked during local login. No full onboarding/approval state-machine audit was completed.

C036 / P1 Numeric edge cases and financial logic

Not verified | Medium evidence/route-candidates.csv; S19:50-72

No identified deployed financial workflow. App/plugin business requirements are needed before calling this not applicable.

6. Complete checklist coverage

Entries 037-045 of 104. Status describes the uploaded baseline. 'Not verified' is an evidence gap, not Pass or N/A. For unknown rows, severity is review priority, not a confirmed finding.

C037 / P2 Replay and idempotency

Not verified | High S09:288-299; S28:114-131

One-time token updates are non-atomic and outgoing webhooks lack receiver dedup context. Payment/inbound-event applicability is unknown.

C038 / P2 Abuse of legitimate features

Not verified | Medium S24:94-117; S43:19-97

Auth rate-limit hooks exist. Search/export/invitation quotas and distributed behavior are not proven.

C039 / P3 Time-based logic

Not verified | Medium S29:38-40; S09:288-299

Lifespans are server-configured. Patch adds server-time reset expiry; DST/boundary/session clock tests are still required.

C040 / P1 Hardcoded credentials and secrets

Fail | High S05:3-30; S04:12-14; S01:7-10

Fallback credentials exist. F02 removes those in listed configs. Pattern inventory omits secret values; git history was excluded and no full Gitleaks history scan occurred.

C041 / P1 Password hashing

Not verified | Medium S21:49-56,157

bcrypt hashing defaults to cost 10; verification uses bcrypt.compare. Configurable costs, legacy hashes and password-length policy require validation.

C042 / P1 Symmetric encryption

Fail | High S11:10-32,47-51; S12:140

Export encryption defaults to AES-128-ECB with fixed empty KDF salt; CBC options derive IV from the key. F06 remains; changing format requires coordinated import/export migration.

C043 / P2 Randomness

Not verified | Medium S09:503; S37:26

Reset tokens and GCM IVs use crypto.randomBytes. Other random values were not comprehensively classified by security purpose.

C044 / P2 Signature and MAC verification

Not verified | Medium S38:45; S22:91-99

An audit-log export token uses constant-time comparison; JWT library performs verification. Every signature path has not been verified.

C045 / P2 TLS usage in outbound calls

Not verified | Medium S08:145-149; S28:117-131

Fetch relies on platform TLS checks. Custom proxy/provider trust stores and environment-level overrides need deployment review.

6. Complete checklist coverage

Entries 046-054 of 104. Status describes the uploaded baseline. 'Not verified' is an evidence gap, not Pass or N/A. For unknown rows, severity is review priority, not a confirmed finding.

C046 / P3 Key management

Not verified | Medium S37:7-15; S05:29-30

Admin encryption key is configured via environment; fallback removed. No KMS, cross-environment isolation or rotation plan was supplied.

C047 / P1 Fail-closed behavior

Fail | Medium S09:372-390; S18:37-55

Logout swallowed revoke exceptions and returned success. F08 now returns an error on exceptions; non-throwing failures and other fallback paths need review.

C048 / P2 Sensitive data in logs

Not verified | Medium S08:126-159; S28:144-148

URL-containing errors and fetch debug messages can expose user-influenced values. Central redaction and log-retention behavior need review.

C049 / P2 Security event logging

Not verified | Medium S05:21-23; S18:42-54

Audit-log capability and denial responses exist. Actual enabled logging, SIEM forwarding, alerts and request IDs are not verified.

C050 / P2 Debug and default configuration

Fail | High S04:30-48; S05:3-30; S34:9-10,37

Examples enable verbose logs/MCP and carry weak secrets; helper server bound broadly. F01/F02 harden bindings/secrets, but example debug features remain review-required.

C051 / P2 Input validation strategy

Not verified | Medium S19:25-26,60-62; S20:121-123

Boundary validation exists in core CRUD. Duplicate-key behavior, every custom route and body-size settings need verification.

C052 / P1 Known-vulnerable dependencies

Fail | High S33; evidence/osv-results.json; evidence/osv-advisories.json

OSV queried all 2,838 root lockfile package/version pairs; 44 pairs matched 111 unique advisory IDs. F10 is advisory evidence, not proof of deployed reachability.

C053 / P2 Lockfiles, pinned versions, and integrity hashes

Fail | Medium S01:5,17; S33:5-13

Yarn lock has integrity checks, but Compose PostgreSQL tag was unpinned and MySQL only major-pinned. Patch requires operator-selected tested images/digests; other lockfiles not SCA-scanned.

C054 / P2 Dangerous install scripts and unmaintained packages

Not verified | Medium S32:59-62; evidence/packages.json

Root postinstall runs husky. Install hooks were inventoried, not executed. Transitive install scripts and package maintenance require deeper review.

6. Complete checklist coverage

Entries 055-063 of 104. Status describes the uploaded baseline. 'Not verified' is an evidence gap, not Pass or N/A. For unknown rows, severity is review priority, not a confirmed finding.

C055 / P1 CORS policy

Fail | High S07:16-22,64-70

Baseline wildcard origin reflects request Origin with credentials enabled. F03 denies cross-origin by default; no running-browser verification was performed.

C056 / P1 TLS and HSTS

Not verified | High S16:22-25

HSTS middleware exists. No TLS endpoint, certificate chain, reverse proxy or HTTPS redirect was supplied.

C057 / P1 HTTP security headers

Fail | Medium S16:49-75,87-99

Documentation/playground paths add unsafe-inline and broad script exceptions. F11 remains; nonce-compatible UI migration and deployed header checks are required.

C058 / P1 Cookie attributes

Not verified | High S29:43-69

HttpOnly/SameSite cookie options exist; Secure depends on environment/proxy and overrides. All auth cookies were not checked on the wire.

C059 / P2 Caching of sensitive responses

Not verified | Medium S27:31-75; S19:24-44

No deployed cache/proxy behavior was available. Sensitive responses must be tested for Cache-Control:no-store.

C060 / P2 Subdomain and DNS hygiene

Not verified | Medium No DNS/host inventory supplied; no source file/line can establish deployed DNS hygiene.

Subdomain ownership, dangling CNAMEs and staging exposure require the approved host list.

C061 / P3 Content security reporting

Not verified | Low S16:14-20

No collected CSP-reporting infrastructure was supplied. Test reporting destinations and owners in deployment.

C062 / P1 JWT runtime tests

Not verified | High S22:87-99

Static verification constrains algorithms. No token-tampering, foreign-audience or signature tests against a running app were conducted.

C063 / P1 Session revocation

Not verified | High S09:356-390; regression-results.json

Focused mocked logout error test passes after patch. Actual old access/refresh token replay after logout/password/role changes remains untested.

6. Complete checklist coverage

Entries 064-072 of 104. Status describes the uploaded baseline. 'Not verified' is an evidence gap, not Pass or N/A. For unknown rows, severity is review priority, not a confirmed finding.

C064 / P1 Rate limiting and anti-automation

Not verified | High S24:62-117; S43:19-97

Auth rate-limit hooks exist. No distributed-store, forwarded-IP spoofing or concurrent limit checks against a deployed service.

C065 / P1 Error suppression

Not verified | High S27:64-75

Generic internal-error formatting is observed. Malformed-body and exception tests on all public surfaces were not run.

C066 / P1 Authorization runtime verification (BOLA/BFLA)

Not verified | High S18:85-92; evidence/route-candidates.csv

No two-user/two-tenant/admin test accounts or running app supplied. BOLA/BFLA runtime verification remains mandatory.

C067 / P2 User enumeration

Not verified | Medium S09:164-189,496-498

Login errors are generic for absent/wrong credentials, but blocked/unconfirmed responses differ. Enumeration timing and registration behavior remain untested.

C068 / P2 Password policy and MFA enforcement

Not verified | High S10:35-40; S21:49-56

Model minimum password length is six; deployment validation/MFA policy unknown. No live weak/breached-password tests were performed.

C069 / P2 Session handling in practice

Not verified | Medium S29:38-40,73-95

Configured session lifespans are visible. Fixation, concurrent sessions, idle expiry and actual cookie scope are not runtime-tested.

C070 / P2 CSRF runtime check

Not verified | Medium S29:43-69; S14:199-220

Browser cross-site JSON/multipart/refresh tests are deferred. SameSite or Apollo settings alone do not prove CSRF protection.

C071 / P1 SSRF and cloud metadata access

Not verified | High S08:133-149

Mocked tests cover blocked DNS answers and redirect:error. No cloud metadata/internal network/OOB probes were run; DNS-rebinding risk remains.

C072 / P2 HTTP request smuggling and desync

Not verified | Medium No deployed proxy chain supplied; no source file/line proves parser agreement.

Request-smuggling tests need front/back proxy topology and separately approved safe runtime testing.

6. Complete checklist coverage

Entries 073-081 of 104. Status describes the uploaded baseline. 'Not verified' is an evidence gap, not Pass or N/A. For unknown rows, severity is review priority, not a confirmed finding.

C073 / P2 Host header and routing attacks

Not verified | Medium S35:20-23; S09:509-511

Reset URLs use configured base URLs. Forwarded-header trust, host routing and virtual-host isolation need deployment validation.

C074 / P2 Web cache poisoning and deception

Not verified | Medium No cache/CDN configuration supplied; source line evidence unavailable.

Unkeyed-header poisoning and path-confusion behavior require the actual cache configuration.

C075 / P1 Inbound webhook verification

Not verified | High S28:114-131; evidence/route-candidates.csv

Observed runner is outgoing, not proof of inbound webhook validation. Installed inbound payment/provider integrations are unknown.

C076 / P2 WebSockets and server-sent events

Not verified | Medium S13:4; evidence/route-candidates.csv

GraphQL subscriptions default off. Other data-transfer/admin SSE/WebSocket authentication and origin checks need testing.

C077 / P3 Exposed internal services

Not verified | Medium S01:13-14,27-28; S34:37; S04:46-48

Source exposed development services. Bind patches reduce default exposure; no public port scan or cloud firewall inspection occurred.

C078 / P1 Disable introspection and suggestions in production

Not verified | Medium S13:5-6; S14:199-225

Patch disables production introspection by default. Suggestion suppression and real enabled-plugin behavior remain unverified.

C079 / P1 Query depth, complexity, and cost limits

Fail | Medium S13:5; S14:149-158,203-206

Baseline maxLimit:-1 and unset depth only trigger warnings. F07 sets finite depth/pagination; cost/alias amplification limits still need implementation.

C080 / P1 Batching and alias abuse

Not verified | High S14:199-232; S43:19-97

Patch explicitly disables HTTP batching. Alias-based amplification and per-operation rate accounting remain unresolved.

C081 / P1 Field-level authorization

Not verified | High S30:137-163

Top-level and configured-field authorization exist; unconfigured nested fields do not automatically inherit object ownership. Cross-role/tenant queries need tests.

6. Complete checklist coverage

Entries 082-090 of 104. Status describes the uploaded baseline. 'Not verified' is an evidence gap, not Pass or N/A. For unknown rows, severity is review priority, not a confirmed finding.

C082 / P2 Persisted queries and input validation

Not verified | Medium S14:136-138,203-206

Typed schema generation exists. Persisted query allowlists and custom resolver input coverage were not supplied.

C083 / P2 API gateway controls

Not verified | Medium S42:398-405; no gateway deployment configuration supplied

Loopback defaults narrow direct access. Gateway-only reachability, quotas and consistent API version policy need actual topology.

C084 / P2 Inventory and shadow APIs

Not verified | Medium evidence/route-candidates.csv; S18:76-95

Partial source route inventory is delivered. Enabled dynamic endpoints, JS bundles and version ownership require runtime inventory.

C085 / P1 Reflected, stored, and DOM XSS runtime tests

Not verified | High S25:12-20; S26:67-74

Static WYSIWYG sanitizer verified. No reflected/stored/DOM browser payload tests were executed.

C086 / P2 Clickjacking

Not verified | Medium S16:26-28

Sameorigin frameguard is configured; sensitive pages must be tested against required frame-ancestors policy.

C087 / P2 Sensitive data in client storage and bundles

Fail | Medium S15:131-156

Admin remember-me mode writes access JWTs to localStorage. F09 remains; no public bundle/source-map inspection was possible.

C088 / P2 Third-party scripts

Not verified | Medium S16:49-61

Documentation/playground permits third-party CDN scripts. Actual SRI, deployed script inventory and integrity policy are unverified.

C089 / P3 postMessage and cross-origin communication

Not verified | Medium evidence/source-pattern-inventory.json (browser_sinks)

Preview postMessage locations are inventoried. Sender origin/receiver checks require targeted review and browser tests.

C090 / P1 Upload abuse tests

Not verified | High S17:53-54,87-96; S36:271-287

MIME detection and extension exceptions exist. No active SVG, polyglot, decompression or oversized upload tests were performed.

6. Complete checklist coverage

Entries 091-099 of 104. Status describes the uploaded baseline. 'Not verified' is an evidence gap, not Pass or N/A. For unknown rows, severity is review priority, not a confirmed finding.

C091 / P2 Download and export features

Not verified | Medium S08:288-310; S38:45

Signed URL/token controls observed. Cross-user downloads, CSV formula injection and actual URL expiry remain untested.

C092 / P2 Document and image processors

Not verified | Medium S36:234-244; evidence/packages.json

Native image/file processing dependencies exist; sandbox, network isolation and resource budgets are deployment-dependent and untested.

C093 / P1 Public cloud storage and backups

Not verified | High S17:53-54; no cloud/bucket/backup inventory supplied

No public storage enumeration or web-root backup probes were run. Public directory uploads are not proof of bucket misconfiguration.

C094 / P2 Container and orchestrator exposure

Not verified | Medium S01:1-28; S03:1-39

Compose files were reviewed. Docker daemon/Kubernetes API/firewall exposure cannot be established from source.

C095 / P2 Default pages, versions, and verbose banners

Not verified | Medium S34:27-38; S16:41-75

Development documentation/example features are present. Deployed default pages and version banners are unknown.

C096 / P3 Denial-of-service resilience

Not verified | Medium S13:5; S14:149-158

No load/DoS testing was authorized for remote systems or performed. Finite GraphQL defaults mitigate only some resource risks.

C097 / P2 Verify that attacks are detected

Not verified | Medium No SIEM/WAF access or detection logs supplied; source-line evidence unavailable.

Representative attacks must be correlated to alerts with owners/runbooks in staging.

C098 / P2 WAF and bot controls tuned

Not verified | Medium No WAF/bot configuration supplied; source-line evidence unavailable.

Blocking mode, false positives and independent application defenses require operational review.

C099 / P1 Rate findings consistently

Not verified | Medium AppSec-Audit.pdf sections 3-4; findings.json

Qualitative severity/rationale and proposed owning teams are included. Production business context and confirmed reachability are missing, so final CVSS scores are not assigned.

6. Complete checklist coverage

Entries 100-104 of 104. Status describes the uploaded baseline. 'Not verified' is an evidence gap, not Pass or N/A. For unknown rows, severity is review priority, not a confirmed finding.

C100 / P1 Provide reproducible evidence and fixes

Pass | Low findings.json; security-fixes.patch; change-manifest.json

Each finding includes baseline file/line, code evidence, impact, fix or explicit open remediation, and verification scope.

C101 / P1 Fix root causes, not instances

Not verified | Medium security-fixes.patch; findings.json

Repeated binding/secret defaults are patched across generators/configs. Architectural auth, SSRF, crypto and token-storage fixes remain open.

C102 / P2 Retest

Not verified | High regression-results.json

Nineteen focused mocked/source-level test groups pass and patch applicability is verified. Full build/typecheck and runtime retest remain undone.

C103 / P2 Feed results back into the SDLC

Not verified | Medium tests/security-regression.cjs; evidence/packages.json

Regression harness and follow-up plan delivered. CI integration, policy tests and custom Semgrep/CodeQL rules remain operator work.

C104 / P3 Track trends

Not verified | Low findings.json; change-manifest.json

A baseline exists. Historical remediation time, recurrence and full endpoint coverage metrics were not supplied.

7. Source reference map

All Sxx line numbers refer to the original uploaded baseline. Paths are relative to the strapi repository root. Patched line numbers can shift; consult security-fixes.patch for exact changes. Artifact paths refer to this deliverable bundle.

S01 docker-compose.dev.yml

S02 docker-compose.test.yml

S03 examples/complex/docker-compose.dev.yml

S04 examples/getstarted/config/server.js

S05 examples/getstarted/config/admin.js

S06 examples/getstarted/config/database.js

S07 packages/core/core/src/middlewares/cors.ts

S08 packages/core/upload/server/src/services/file.ts

S09 packages/plugins/users-permissions/server/src/controllers/auth.js

S10 packages/plugins/users-permissions/server/src/content-types/user/index.js

S11 packages/core/data-transfer/src/utils/encryption/encrypt.ts

S12 packages/core/data-transfer/src/file/providers/destination/index.ts

S13 packages/plugins/graphql/server/src/config/default-config.ts

S14 packages/plugins/graphql/server/src/bootstrap.ts

S15 packages/core/admin/admin/src/utils/getFetchClient.ts

7. Source reference map

All Sxx line numbers refer to the original uploaded baseline. Paths are relative to the strapi repository root. Patched line numbers can shift; consult security-fixes.patch for exact changes. Artifact paths refer to this deliverable bundle.

S16 packages/core/core/src/middlewares/security.ts

S17 packages/providers/upload-local/src/index.ts

S18 packages/core/core/src/services/server/compose-endpoint.ts

S19 packages/core/core/src/core-api/controller/collection-type.ts

S20 packages/core/database/src/query/helpers/where.ts

S21 packages/plugins/users-permissions/server/src/services/user.js

S22 packages/plugins/users-permissions/server/src/services/jwt.js

S23 packages/plugins/users-permissions/server/src/config.js

S24 packages/plugins/users-permissions/server/src/middlewares/rateLimit.js

S25 packages/core/content-manager/admin/src/pages/EditView/components/FormInputs/Wysiwyg/PreviewWysiwyg.tsx

S26 packages/core/content-manager/admin/src/pages/EditView/components/FormInputs/Wysiwyg/utils/sanitizer.ts

S27 packages/core/core/src/services/errors.ts

S28 packages/core/core/src/services/webhook-runner.ts

S29 packages/core/admin/shared/utils/session-auth.ts

S30 packages/plugins/graphql/server/src/services/content-api/wrap-resolvers.ts

7. Source reference map

All Sxx line numbers refer to the original uploaded baseline. Paths are relative to the strapi repository root. Patched line numbers can shift; consult security-fixes.patch for exact changes. Artifact paths refer to this deliverable bundle.

S31 packages/core/core/package.json

S32 package.json

S33 yarn.lock

S34 scripts/open-api/serve.js

S35 packages/core/core/src/configuration/index.ts

S36 packages/core/upload/server/src/utils/mime-validation.ts

S37 packages/core/admin/server/src/services/encryption.ts

S38 packages/core/admin/ee/server/src/audit-logs/utils/export-token.ts

S39 packages/plugins/users-permissions/server/src/controllers/user.js

S40 packages/core/core/src/services/auth/index.ts

S41 packages/cli/create-strapi-app/src/utils/dot-env.ts

S42 packages/core/core/src/Strapi.ts

S43 packages/plugins/users-permissions/server/src/routes/content-api/auth.js

Public dependency evidence

OSV API: https://api.osv.dev/v1/querybatch
Advisory details: https://api.osv.dev/v1/vulns/{advisory-id}
Examples: GHSA-9q82-xgwf-vj6h (Apollo XS-Search prevention bypass); GHSA-7mx3-vvmw-hjmv (GraphQL utility prototype pollution).
Full records and ranges are retained in evidence/osv-advisories.json.

Assessment limits

This report does not certify the application as secure. Missing source-line evidence for DNS, TLS, caches, SIEM/WAF and cloud infrastructure is explicitly identified rather than invented. Complete staging retest, remediation ownership and deployment context are required for final release approval.